

Why You Need Responsible Disclosure and How to Get Started

What Is Responsible Disclosure?

Responsible disclosure, also known as coordinated vulnerability disclosure, is a process in which security researchers or ethical hackers discover vulnerabilities, weaknesses, or flaws in software, hardware, or systems and report them to the affected organization or vendor. The main goal of responsible disclosure is to improve security by addressing vulnerabilities before they can be exploited by malicious actors.

The process usually involves the following steps:

1. **Discovery:** Security researchers or ethical hackers find a vulnerability in a system or software.
2. **Reporting:** They report the vulnerability to the affected organization, vendor, or a relevant third-party, such as a bug bounty platform, in a secure and confidential manner.
3. **Verification:** The organization or vendor acknowledges the report, reviews the vulnerability, and verifies its existence.
4. **Remediation:** The organization or vendor works on developing a patch or fix to address the vulnerability.
5. **Disclosure:** Once the fix is ready, the vulnerability is publicly disclosed, often with credit given to the researcher who discovered it. This may also include releasing details about the vulnerability, its potential impact, and advice on how to mitigate or protect against it.

Responsible disclosure helps protect users and systems from potential attacks by allowing organizations to address vulnerabilities before they become widely known. This approach encourages collaboration between security researchers and affected parties, promoting a more secure digital environment for everyone.

What Is the Difference Between Responsible Disclosure and Bug Bounty?

Both responsible disclosure and bug bounty programs aim to improve security and protect users, but they differ in terms of process, rewards, collaboration, formality, and scope. Here is a table comparison that explains these differences:

Aspect	Responsible Disclosure	Bug Bounty Program
Objective	Improve security through coordinated disclosure	Incentivize vulnerability discovery with rewards
Process	Discover, report, verify, remediate, disclose	Define scope/rules, discover, report, reward
Rewards	Not mandatory or expected	Offered based on severity and program terms
Collaboration	Encourages collaboration between parties	Encourages active participation of researchers
Program management	Often informal, no specific program defined	Structured program with defined rules and scope
Scope	May be broad or undefined	Clearly defined by the organization
Public recognition	May or may not be provided	Usually provided, depending on program rules

In summary, responsible disclosure is a process that emphasizes coordinated reporting and addressing of vulnerabilities, while bug bounty programs are designed to incentivize vulnerability discovery through financial or other rewards. Both approaches share the common goal of improving security and protecting users, but they differ in their methods and incentives.

Learn more in our detailed guide to bug bounty program (coming soon)

What Are the Benefits of a Responsible Disclosure Program?

There are several benefits to practicing responsible disclosure, including:

- **Increased security:** The primary benefit of responsible disclosure is that it helps to increase the security of software, hardware, and systems. By allowing vendors and organizations to address vulnerabilities before they can be exploited by malicious actors, responsible disclosure helps to prevent data breaches, identity theft, and other types of cybercrime.

- **Improved collaboration:** Responsible disclosure promotes collaboration between security researchers and vendors or organizations. By working together to identify and address security vulnerabilities, vendors and researchers can develop stronger and more secure products and systems.
- **Trust and reputation:** Responsible disclosure helps to build trust and improve the reputation of both vendors and security researchers. Vendors that respond promptly and professionally to security vulnerabilities are viewed as more trustworthy and responsible, while security researchers who follow responsible disclosure practices are seen as ethical and responsible members of the security community.
- **Legal protection:** Following responsible disclosure practices can also provide legal protection for security researchers. By reporting vulnerabilities to vendors or organizations before disclosing them publicly, researchers can avoid potential legal issues related to unauthorized access or hacking.
- **Public safety:** Responsible disclosure also benefits public safety by reducing the risk of cyberattacks and other security incidents that could result in harm to individuals or organizations.

Challenges of Following a Responsible Disclosure Process

Following a responsible disclosure process can be beneficial to both security researchers and organizations, but it also presents several challenges. Here are some of the key challenges that stakeholders may face while following a responsible disclosure process:

- **Balancing interests:** Organizations must strike a balance between the need for immediate remediation and the desire to keep vulnerabilities confidential to minimize potential harm. At the same time, researchers may want to publish their findings to gain recognition or share knowledge within the community.
- **Timely response and remediation:** Organizations may struggle to respond quickly to vulnerability reports or take longer than expected to develop and deploy patches. This can lead to frustration for researchers and increased risk for users.
- **Communication barriers:** Effective communication between researchers and organizations is crucial, but language barriers, time zones, or a lack of clarity in communications can hinder the process.
- **Coordinated disclosure:** When multiple parties are affected by a vulnerability, coordinating the disclosure and remediation process can be complex. Ensuring that all stakeholders are informed and patches are released simultaneously can be challenging.
- **False positives and duplicate reports:** Organizations must have a process in place to handle false positives and duplicate reports. This can be time-consuming and may detract from efforts to address genuine vulnerabilities.

Addressing these challenges requires a cooperative approach, with organizations and researchers working together to improve security while respecting each other's interests and concerns.

How to Set Up a Responsible Disclosure Policy

Setting up a responsible disclosure policy is essential for organizations that want to encourage security researchers to report vulnerabilities in a controlled and mutually beneficial manner. To establish an effective policy, follow these steps:

1. Define the Policy's Purpose and Scope

Clearly outline the objectives of your responsible disclosure policy, such as identifying and addressing security vulnerabilities. Specify the scope of systems, applications, and services covered by the policy.

2. Establish Reporting Guidelines

Provide clear instructions for security researchers on how to report vulnerabilities. Include information on:

- The preferred method of communication (e.g., email, web form, or vulnerability reporting platform).
- The information that should be included in the report, such as a description of the vulnerability, steps to reproduce the issue, and any potential impact or risks.
- Any encryption requirements for secure communication (e.g., using PGP).

3. Set Expectations for Response and Resolution

Outline your organization's commitment to addressing reported vulnerabilities, including:

- An estimated response time for acknowledging receipt of the report.
- The process for validating, prioritizing, and remediating identified vulnerabilities.
- The expected timeline for resolution, if possible.

4. Offer Safe Harbor Provisions

Provide assurances to researchers that they will not face legal action if they adhere to your responsible disclosure policy. Consider including a statement that explicitly grants permission

for security research activities and exempts researchers from liability, provided they follow your guidelines.

5. Outline Communication Guidelines

Define how your organization will communicate with researchers during the disclosure process, including updates on the progress of vulnerability remediation and any potential delays.

6. Detail Incentives or Recognition

If your organization offers incentives, such as monetary rewards, merchandise, or public recognition, provide details on the criteria used to determine rewards and how researchers can claim them.

7. Develop a Coordinated Disclosure Plan

Outline your organization's approach to coordinated disclosure, detailing how you will work with affected parties and third-party vendors if a vulnerability impacts multiple systems or organizations.

8. Assign Responsibility and Resources

Designate a team or individual responsible for handling vulnerability reports, addressing issues, and communicating with researchers. Ensure they have the necessary resources and authority to fulfill their responsibilities.

9. Promote the Policy

Make your responsible disclosure policy easily accessible on your website or other relevant platforms. Inform employees and stakeholders about the policy and its importance.

10. Review and Update the Policy

Regularly review and update your policy to keep it current and relevant. Incorporate feedback from researchers, internal stakeholders, and industry best practices to improve its effectiveness.

By establishing a clear and well-communicated responsible disclosure policy, you can create a collaborative environment that encourages security researchers to report vulnerabilities,

ultimately enhancing the security of your systems and protecting your users.

Responsible Disclosure with HackerOne

Vulnerability disclosure can be contentious depending on the organization receiving the disclosure. Some organizations prefer not to disclose weaknesses publicly until they are remediated, while sometimes the researcher prefers the organization makes flaws public sooner. Having a designated Vulnerability Disclosure Program (VDP) or bug bounty program can help your organization provide controlled and collaborative environments where researchers and developers follow set guidelines to solve security issues together.

HackerOne provides a centrally managed platform to provide clear and concise channels for responsible vulnerability disclosure. Whether through a funded bug bounty program with [HackerOne Bounty](#), or a VDP with [HackerOne Response](#), businesses can set the terms and scope of their program to remove any ambiguity among security researchers.

To protect security researchers, HackerOne launched its [Gold Standard Safe Harbor \(GSSH\)](#) statement for customers, which supports the protection of ethical hackers from liability when hacking in good faith. The GSSH makes it simple for all HackerOne customers to adopt safe harbor policies to encourage security researcher engagement and, ultimately, maximize their attack resistance.

For more details on HackerOne’s Gold Standard Safe Harbor statement, read the [official press release](#).

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a [+](#)
hacker?

DevSecOps